

---

✅ 1. Introduce yourself and describe your day-to-day activities in your previous role

**Example Answer:**

*"I am an SAP Security and GRC Consultant with over X years of experience in user administration, role design, access control, and compliance. My daily activities included user creation and deletion, role creation and modification, authorization troubleshooting, handling transport requests, performing security audits, supporting SOX compliance, coordinating with functional and technical teams, and preparing documentation."*

---

✅ 2. What are the mandatory fields for user creation?

- User ID
  - Last Name
  - User Type
  - Password (initial)
  - Validity dates
  - User Group (recommended)
  - Roles/Profiles (as needed)
- 

✅ 3. How many types are there?

**User Types in SAP:**

1. **Dialog** — Interactive login.
  2. **System** — For background processing, RFCs.
  3. **Communication** — For external system communication (RFC, etc.).
  4. **Service** — For anonymous, multiple logins (e.g., web applications).
  5. **Reference** — For assigning authorizations indirectly (used for Internet users).
- 

✅ 4. Difference between Service user and Dialog user?

|                 | <b>Service User</b>            | <b>Dialog User</b>                 |
|-----------------|--------------------------------|------------------------------------|
| Use             | For anonymous, multiple logins | For interactive, individual logins |
| Password Change | No enforced password change    | Password change enforced           |
| Multiple logins | Allowed                        | Restricted (if configured)         |
| Example         | Web shop guest access          | End-user login to SAP GUI          |

---

#### 5. Difference between Service User and Communication User?

|                   | <b>Service User</b>                     | <b>Communication User</b>               |
|-------------------|-----------------------------------------|-----------------------------------------|
| Use               | For anonymous multiple users (web apps) | For communication between systems (RFC) |
| Interactive Login | Allowed                                 | Not for interactive login               |
| Multiple logins   | Allowed                                 | Not applicable — used programmatically  |

---

#### 6. Difference between System User and Communication User?

|               | <b>System User</b>                      | <b>Communication User</b>                |
|---------------|-----------------------------------------|------------------------------------------|
| Use           | Background jobs, system processes, RFCs | For external communication (RFC clients) |
| Logon         | No interactive login                    | No interactive login                     |
| Lock behavior | Not locked on failed login              | Not locked on failed login               |

---

#### 7. Can we use Communication User for Background Job Scheduling?

✗ No.

For background jobs, **System Users** are recommended because they're designed for background processing and don't lock on failed logins.

---

✓ 8. What is Reference User for? How do we use Reference User?

- **Purpose:** Assign additional authorizations indirectly.
  - **Usage:** Assign the Reference User in the *Roles tab* → *Reference User field* in SU01.  
Example: Internet users who need additional permissions beyond basic access.
- 

✓ 9. Types of Locks?

1. **User Lock:** By administrator (SU01).
  2. **Automatic Lock:** After failed login attempts.
  3. **Lock by system:** If user's validity date expires.
- 

✓ 10. Types of Return Codes? (SAP Security Trace)

In **ST01/STAUTHTRACE**:

- **0:** Authorized
  - **4:** Not authorized
  - **8:** Authorization check error
  - **12:** Invalid authorization object
- 

✓ 11. Maximum number of profiles assignable to a user?

**312 profiles** maximum (per user).

---

✓ 12. Difference between User Group in Logon Data Tab and in SU01?

|          | User Group in Logon Data                 | SU01 User Group                                                 |
|----------|------------------------------------------|-----------------------------------------------------------------|
| Location | SU01 → Logon Data tab                    | Also visible in SU01 overview                                   |
| Purpose  | Controls which admin can manage the user | Same — both represent user classification for admin restriction |
| Note     | Maintained in same place; not different  |                                                                 |

---

### ✓ 13. Difference between TABU\_DIS and TABU\_NAM?

|         | TABU_DIS                                                         | TABU_NAM                                           |
|---------|------------------------------------------------------------------|----------------------------------------------------|
| Purpose | Authorizes table maintenance based on <b>authorization group</b> | Authorizes maintenance for a <b>specific table</b> |
| Scope   | Broader — group level                                            | Specific — table name                              |

---

### ✓ 14. Functional difference between Parameters and Roles?

|            | Parameters                                                          | Roles                                  |
|------------|---------------------------------------------------------------------|----------------------------------------|
| Definition | User-specific system variables (like default printer, company code) | Collection of authorizations and menus |
| Purpose    | Controls user-specific settings                                     | Controls user's access permissions     |
| Example    | Parameter ID: WRK (Plant)                                           | Role: ZFI_AP_MANAGER                   |

---

### ✓ 15. Tcode to set password parameters?

**RZ10 / RZ11** — to maintain profile parameters (like login/min\_password\_lng, login/fails\_to\_user\_lock)

---

### ✓ 16. Remember the table starting with AGR

- **AGR\_1251** — Role authorization data
  - **AGR\_USERS** — Users assigned to roles
  - **AGR\_DEFINE** — Role definition
- 

#### ✓ 17. Difference between Master and Derived Role?

|            | Master Role                          | Derived Role                                          |
|------------|--------------------------------------|-------------------------------------------------------|
| Definition | Contains the full authorization data | Inherits authorizations but uses different org levels |
| Used for   | Common tasks across org units        | For multiple org units (e.g., Company Code)           |
| Example    | ZFI_AP_MASTER                        | ZFI_AP_CC1000                                         |

---

#### ✓ 18. How is Master Role used?

Master Role stores common activities and permissions. Derived Roles inherit this and override only organizational levels.

---

#### ✓ 19. How is Derived Role used?

Derived Role is assigned to users needing same access as Master Role but for different org units — for example, different plants or company codes.

---

#### ✓ 20. Different types of Authorization Object Status in Role Creation?

- **Standard:** SAP standard object
  - **Changed:** Manually adjusted in role
  - **Maintained:** Values provided
  - **Maintained with errors:** Incomplete or inconsistent
- 

#### ✓ 21. Options in Expert Mode for Role Modification?

- Expert mode allows:
    - Adjusting org levels
    - Changing authorization data manually
    - Comparing role data with SU24 proposals
- 

✓ 22. Difference between Manual Mode and Expert Mode?

|             | Manual Mode                                | Expert Mode                                             |
|-------------|--------------------------------------------|---------------------------------------------------------|
| Usage       | Change authorizations in PFCG step by step | Advanced: adjust org levels, compare, reset, regenerate |
| Flexibility | Limited                                    | More powerful control                                   |

---

✓ 23. How many Derived Roles can be derived from 1 Master Role?

**No hard limit** — multiple **Derived Roles** can be created, usually one per org unit variation.

---

✓ 24. How to find Master Role of a Derived Role (and vice versa)?

- In **PFCG**, open Derived Role → “Role” tab shows “Derived From”.
  - Or check **AGR\_DEFINE** table.
- 

✓ 25. How will you change an authorization field for a Derived Role?

Change the authorization field in the **Master Role**, then regenerate Derived Roles OR manually adjust the Derived Role in expert mode if needed.

---

✓ 26. How to find the Composite Role of a Single Role?

Use **table AGR\_AGRS** — it shows the relationship between Composite and Single Roles.

---

✓ 27. Necessary Authorization Objects for Security Admin to run SU01

- **S\_USER\_GRP** — User group maintenance
  - **S\_USER\_PRO** — Profile assignment
  - **S\_USER\_AUT** — Authorization maintenance
  - **S\_USER\_TCD** — Authorization for transactions
- 

✅ **28. Table to check authorization data of a TCODE?**

**Table: AGR\_1251** — contains objects and field values for roles.

---

✅ **29. Tcodes to display or change authorization data?**

- **PFCG** — Create/change role & auth
  - **SU24** — Maintain TCODE → Auth object proposals
  - **SU03** — Maintain Auth objects
- 

✅ **30. SU53, SU56, ST01, STAUTHTRACE and internal difference**

| Tcode       | Use                                                    |
|-------------|--------------------------------------------------------|
| <b>SU53</b> | Shows last failed authorization check for current user |
| <b>SU56</b> | Shows current user's buffer                            |
| <b>ST01</b> | System trace (performance + auth)                      |

**STAUTHTRACE** Specialized for authorization trace only; more user-friendly

---

✅ **31. Suppose you find a role modified with critical access by a security admin who is no longer with the organization. What steps will you follow to resolve it?**

1. Identify the role and log of changes (**PFCG, SUIM → Change documents**).
2. Validate the impact: check who is assigned to the role.
3. Discuss with stakeholders/owners if the access is needed.

4. Remove or correct excess access.
5. Document the incident for audit.
6. Communicate with compliance team for review.
7. Implement preventive controls: adjust change management process, limit role modification permissions.